

medicosporvenezuela

Aviso Preliminar de Seguridad — Hallazgo Crítico

Médicos por Venezuela — API Backend

PT-001: Escalada de privilegios mediante finalización de rol en autoservicio

Severidad	Crítica
CVSS 3.1	9.6 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N)
Objetivo	API FastAPI de cola de telemedicina (/api/v1)

Aviso interino para que el equipo de desarrollo remedie un hallazgo crítico validado sin esperar el informe completo del compromiso. Pueden seguir hallazgos adicionales.

1. Resumen Ejecutivo

- Nivel de riesgo general:** Crítico (un único hallazgo validado en este aviso)
- Estado:** Confirmado en revisión de código y validado en un entorno de producción autorizado
- Área de mayor riesgo:** Otorgamiento de rol médico en autoservicio (POST /profiles/me/finalize-role)
- Corrección más importante:** Dejar de auto-verificar médicos y otorgar RBAC de personal hasta que SACS/FPV (o aprobación administrativa) tenga éxito

El análisis estático identificó que finalize_role asigna verified=True para role=doctor sin invocar la ruta SACS/FPV usada por POST /doctors . Las pruebas autorizadas en producción confirmaron el mismo comportamiento de extremo a extremo: una cuenta registrada por API con role_chosen=false obtuvo permisos de médico y acceso a endpoints de personal sin verificación de credenciales profesionales.

Acción inmediata requerida (P0): Remediar la ruta de auto-verificación de finalize_role y auditar cuentas que pudieran haberla usado.

2. Hallazgo PT-001: finalize_role otorga doctor + verified=True sin SACS/FPV

Severidad: Crítica

Puntuación base CVSS 3.1: 9.6 (Crítica)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Confianza: Alta

Estado: Confirmado (código + validación autorizada en producción)

Categoría: Control de acceso roto / escalada de privilegios (CWE-269 · OWASP API1:2023)

Archivo(s) afectado(s):

- src/services/profiles.py:64-99
- src/routers/profiles.py:54-67
- db/migrations/20260703_221135_sync_user_roles_from_profiles_trigger.sql:15-57

Descripción:

Cualquier usuario autenticado cuyo role_chosen siga en falso puede llamar a POST /api/v1/profiles/me/finalize-role con {"role":"doctor"} . El servicio asigna role=doctor , verified=True y active=True . Al actualizar profiles.role se dispara sync_user_roles_from_profile , que inserta la fila doctor en user_roles , otorgando permisos de personal (patients.read , queue.take , consultations.write , etc.).

El registro de médico vía POST /doctors sí verifica correctamente contra SACS/FPV; esta ruta no. Los campos de licencia / WhatsApp en finalize_role se almacenan solo como metadatos — no se contrastan con ninguno de los registros.

El onboarding por GUI (/registro-medico , /registro-paciente , /elegir-rol) suele fijar role_chosen=true , por lo que FastAPI finalize_role no queda disponible tras un registro normal por GUI. La ruta alcanzable para el atacante es el **registro por API / Auth** que deja la selección de rol abierta (role_chosen=false). La autoasignación de admin se rechaza correctamente (HTTP 422); el defecto es el bypass de verificación de médico, no la asignación irrestricta de roles.

Evidencia (código):

64:89:src/services/profiles.py

```
async def finalize_role(
    ...
) -> Profile:
    ...
    profile.role = role
    if role == "doctor":
        profile.specialty = specialty
        profile.country = country
        profile.medical_license = medical_license
        profile.whatsapp_number = whatsapp_number
    profile.verified = True
    profile.active = True
    profile.role_chosen = True
```

La autenticación sola se convierte en autorización como personal. Se omite la verificación de credenciales que existe en otra ruta. Una vez `verified=True` y el rol doctor sincronizado, el mismo JWT cumple `require_permission` en los endpoints de personal.

Requiere una cuenta válida de Supabase Auth y un perfil con `role_chosen=false` (típico tras registro por API / Google sin asignación de rol por GUI). Alcanzable contra la superficie de producción `/api/v1` cuando se cumple esa precondition.

El defecto estático se confirmó en una **prueba autorizada en producción** con una cuenta dedicada del compromiso, creada vía registro Auth **sin** metadatos de rol por GUI (`role_chosen=false`). Las observaciones coincidieron con la ruta de código anterior.

Paso	Observación	Esperado si está corregido
Acceso base de personal	GET /api/v1/patients y GET /api/v1/queue → 403 para la cuenta previa a finalizar	Igual (denegar hasta verificar)
Finalización de rol	POST /api/v1/profiles/me/finalize-role con role=doctor → 200, verified=true, role_chosen=true	Rechazar o tener éxito con verified=false y sin RBAC de personal
Acceso de personal tras el otorgamiento	Mismo JWT: GET /patients, GET /queue → 200 (listado de personal)	Permanecer en 401/403 hasta que SACS/FPV (o admin) tenga éxito
Control negativo	finalize-role con role=admin → 422	Sin cambios (el tope de admin ya es correcto)

Request	Response
Pretty Raw Hex <pre> 1 GET /api/v1/auth/me HTTP/1.1 2 Host: api.medicosporvenezuela.org 3 Accept: */* 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 5 Authorization: Bearer 6 7 8 9 10 11 12 13 14 Connection: keep-alive 15 16 17 18 19 20 21 22 23 24 25 26 27 28 29 30 31 32 33 34 35 36 37 38 39 40 41 42 43 44 45 46 47 48 49 50 51 52 53 54 55 56 57 58 59 60 61 62 63 64 65 66 67 68 69 70 71 72 73 74 75 76 77 78 79 80 81 82 83 84 85 86 87 88 89 90 91 92 93 94 95 96 97 98 99 100 </pre>	Pretty Raw Hex Render <pre> 1 HTTP/1.1 200 OK 2 Alt-Svc: h3=":443"; ma=2592000 3 Content-Length: 441 4 Content-Type: application/json 5 Date: Sun, 19 Jul 2026 18:00:59 GMT 6 Referrer-Policy: strict-origin-when-cross-origin 7 Server: uvicorn 8 Strict-Transport-Security: max-age=63072000; includeSubDomains; preload 9 Via: 1.1 Caddy 10 X-Content-Type-Options: nosniff 11 X-Correlation-Id: 25199c44ebd2476d930e3bf08c56e49f 12 X-Frame-Options: DENY 13 14 { 15 "email": "attacker-pt-prod1@example.com", 16 "full_name": "attacker-pt-prod1", 17 "role": "patient", 18 "specialty": null, 19 "medical_license": null, 20 "country": null, 21 "whatsapp_number": null, 22 "verified": true, 23 "active": true, 24 "role_chosen": false, 25 "oid_article_b": false, 26 "article_9_doe_path": null, 27 "id": "0e8b206-e72b-4c86-b73a-890214c48cb", 28 "last_seen_at": null, 29 "created_at": "2026-07-19T17:55:18.021251Z", 30 "has_doctor_profile": false, 31 "doctor_cedula": null, 32 "roles": [33 "patient" 34] 35 } </pre>

[illegible]

[Otorgamiento de privilegio] finalize-role → 200 con role=doctor , verified=true .

Request			Response		
Pretty	Raw	Hex	Pretty	Raw	Hex
<pre>1 POST /api/v1/profiles/me/finalize-role HTTP/1.1 2 Host: api1.medicosporvenezuela.org 3 Accept: */* 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 5 Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6ImlpZCQ6ImVudDkwMjAwLWQ5OTctNDRIcz06bnNkLnwqOQMzMjYyKjYnLSIsInR5cCI6Ikpvc3QiLCJodHRwOiJodHdweS50aWhhdGV3FmaOkemZSaahllmNCIGFiYXRlZWlnbWVldGFqdjEILCjzdWIjo1lwOGVlZDIwNW1lLnZjLTJTRjdyYTtyczY5ODAtYmRTMRGMAY2iILCjdndwQ1IjdhxRoZS5oaWhhdGVkliaWZ2bm9jaXoxnzQmdGSmZYULCjpYX01oiE30000MDMyAgImvtYWsioiYXROVFNRZXIrCHQtChJVZFAXhhbXBsZSJjb201CLC3wag9uZSI1ilSiImFwcF9tZXRxZGRFOYSiGeaycm92awRLCi16ImvtYWsLiIdicHVdmLKXZjIjpbImvtYWsLi1l9CLCjcyWZlIDgFKYXRhIjppImvtYWsioiYXROVFNRZXIrCHQtChJVZFAXhhbXBsZSJsb201CLC3wafPbF92ZClpZmZlZC16IHdi1ZSwickvbmVfdmlyawZpZWQ1OmZhbnNLICjzdWIjo1lwOGVlZDIwNW1lLnZjLTJTRjdyYTtyczY5ODAtYmRTMRGMAY2iifSwicm9sZSI6ImFnZGlhbnBpY2F0ZWQ1LChhYWw1OlJhYmxwIiw1Iiw1YyIjpbeyJtZXRob2Q1OLChYWNpd29yc2IsInRpbnVzdGFtcGI6MTc4NDQ0Mzc2Hi1dCLCjZZXnzaw9uw2tiIjo1MDgzZjgxODEyYjZmc00ZTklRW5e30DKtzg4NGYyYjUNZjIiIlwiaXNFVy5vbmltb3V2ZjpmYXcxZk00L3ujOmThmkDiPsRADMc2IEVsYXlla47hiImYmg94nnA_eftfOnokDaDzyKS-PRT4b5JHXJTvoztowYnwG6ZrIetw 6 Content-Type: application/json 7 Content-Length: 137 8 Connection: keep-alive 9 { 10 "role": "doctor", 11 "specialty": "Medicina general", 12 "country": "Venezuela", 13 "medical_license": "PT-TEST-0001", 14 "whatsapp_number": "+58412111111"} }</pre>			<pre>1 HTTP/1.1 200 OK 2 Alt-Svc: h3=:"443"; ma=2592000 3 Content-Length: 472 4 Content-Type: application/json 5 Date: Sun, 19 Jul 2026 18:01:30 GMT 6 Referrer-Policy: strict-origin-when-cross-origin 7 Server: uoyicon 8 Strict-Transport-Security: max-age=63072000; includeSubDomains; preload 9 Via: 1.1 Caddy 10 X-Content-Type-Options: nosniff 11 X-Correlation-Id: 6447ae8B01c64b1b89424912aa2ea666 12 X-Frame-Options: DENY 13 14 { "email": "attacker@pt-prod1@example.com", "full_name": "attacker-pt-prod1", "role": "doctor", "specialty": "Medicina general", "medical_license": "PT-TEST-0001", "country": "Venezuela", "whatsapp_number": "+58412111111", "verified": true, "active": true, "role_chosen": true, "did_article_8": false, "article_8_doc_path": null, "id": "08ebd206-e72b-4c86-b73a-890241c48cb", "last_seen_at": null, "created_at": "2026-07-19T17:55:18.021251Z", "has doctor profile": false, "doctor_cedula": null, "roles": [] }</pre>		

[Impacto] `/api/v1/patients?limit=5` (permisos de médico)

[illegible]

← → ↺

api.medicosporvenezuela.org/api/v1/patients?limit=31

Mk What is the algorithm ... CyberSecurity Tips-Links IT Tips-and-links dailyCheck Extras Articles to Read

JSON Raw Data Headers

Save Copy Collapse All Expand All Filter JSON

needs_tags: []

description: null

user_id: "03e4eba8-9201-4e31-b5a1-42776f6ca672"

allergies: null

parent_id: null

parentesco: null

id: "80ed358f-0062-4f1f-8407-c8d5a130a241"

consent: true

consent_at: "2026-07-19T12:26:58.654829Z"

created_at: "2026-07-19T12:26:58.664394Z"

▼ 1:

full_name: "Marco"

phone_whatsapp: "58 [REDACTED]0"

affected_zone: "Caracas - Sur"

cedula: "V-[REDACTED] 6"

age_range: "27"

email: "m[REDACTED]k.com"

needs_tags: []

description: null

user_id: "5ad49cea-3eb2-4f73-adde-56940265d7df"

allergies: null

parent_id: null

parentesco: null

id: "dfcddae4-5959-40e1-aa86-09253af6c8f6"

consent: true

consent_at: "2026-07-19T00:24:53.354342Z"

created_at: "2026-07-19T00:24:53.370521Z"

▼ 2:

full_name: "Maria [REDACTED]"

phone_whatsapp: "[REDACTED]5"

affected_zone: "Carabobo"

cedula: "V-[REDACTED]"

age_range: "36"

email: "f[REDACTED]l.com"

needs_tags: []

description: null

user_id: "6a777b3f-dabc-4757-b5cd-d44185a10de0"

allergies: null

parent_id: null

parentesco: null

id: "f367e9be-0117-41bf-b649-3d398065d2db"

consent: true

consent_at: "2026-07-18T23:21:24.205998Z"

created_at: "2026-07-18T23:21:24.225455Z"

▼ 3:

full_name: "Lizette [REDACTED]"

phone_whatsapp: "[REDACTED]5 [REDACTED]"

affected_zone: "Caracas - Oeste"

cedula: "V-[REDACTED]"

age_range: "49"

email: "l[REDACTED].com"

needs_tags: []

description: null

user_id: "1b32e76c-4008-4426-9f15-6f233ea3e36a"

allergies: null

parent_id: null

parentesco: null

id: "3fb7e2ac-1218-408e-94ca-3452c694d227"

consent: true

consent_at: "2026-07-17T21:27:37.177567Z"

created_at: "2026-07-17T21:27:37.192674Z"

▼ 4:

[Línea de tiempo] Secuencia ordenada del historial/proxy de los pasos de validación.

188	https://api.medicosporvenezuela.org	GET	/api/v1/queue?limit=5	✓	200	405	JSON	✓	100.50.184.94	14:02:37 19 Jul 2026	8080	61
187	https://api.medicosporvenezuela.org	GET	/api/v1/patients?limit=5	✓	200	2636	JSON	✓	100.50.184.94	14:02:26 19 Jul 2026	8080	78
186	https://api.medicosporvenezuela.org	GET	/api/v1/auth/me	✓	200	894	JSON	✓	100.50.184.94	14:02:21 19 Jul 2026	8080	197
185	https://api.medicosporvenezuela.org	POST	/api/v1/profiles/med/finalize-role	✓	200	877	JSON	✓	100.50.184.94	14:01:31 19 Jul 2026	8080	161
184	https://api.medicosporvenezuela.org	GET	/api/v1/queue?limit=5	✓	403	460	JSON	✓	100.50.184.94	14:01:17 19 Jul 2026	8080	58
183	https://api.medicosporvenezuela.org	GET	/api/v1/patients?limit=5	✓	403	460	JSON	✓	100.50.184.94	14:01:08 19 Jul 2026	8080	56
182	https://api.medicosporvenezuela.org	GET	/api/v1/auth/me	✓	200	848	JSON	✓	100.50.184.94	14:01:00 19 Jul 2026	8080	89

Revisar también PostgREST `rpc/set_my_role` (usado por `/elegir-rol`) por el mismo comportamiento de otorgamiento de privilegios y aplicar la misma política.

4. Corrección Recomendada

- Para `role=doctor` vía `finalize-role`: no asignar `verified=True` ni otorgar RBAC de médico hasta que SACS/FPV (o aprobación administrativa) tenga éxito.
- Preferir: finalizar como médico pendiente (`verified=false`, sin `queue.*` / `patients.read` hasta verificar) o exigir primero `POST /doctors` con verificación exitosa.
- Mantener el tope de roles `patient` / `doctor`; nunca permitir admin por este endpoint (ya está restringido).
- Aplicar la misma política a `set_my_role` y a los triggers de metadatos de registro Auth.
- Auditar cuentas existentes con `role=doctor` + `verified=true` sin verificación de credenciales; poner en cuarentena las sospechosas.

Ejemplo de código seguro:

```
# Pseudocódigo – no auto-verificar médicos
profile.role = role
```

```
profile.role_chosen = True
if role == "doctor":
    profile.verified = False # permisos condicionados a verified + rol pending opcional
    profile.active = True
    # sincronizar a pending_doctor 0 retener doctor hasta confirmación admin/SACS
else:
    profile.verified = True
    profile.active = True
```

Recomendación de prueba de regresión:

Usuario autenticado finaliza como `doctor` → afirmar `verified is False` o afirmar que `GET /patients` / `GET /queue` devuelven 403 hasta completar la verificación. Afirmar que la ruta exitosa de SACS desbloquea los permisos. Cubrir sumideros alternativos (`set_my_role`, metadatos de signup) para que no puedan recrear el bypass.

5. Criterios de Reprueba

Corregido cuando, en un entorno de prueba autorizado:

1. `finalize-role` con `role=doctor` rechaza la verificación pendiente o tiene éxito con `verified=false` (pendiente).
2. `GET /patients` y `GET /queue` permanecen en `401` / `403` hasta que SACS/FPV (o aprobación administrativa) tenga éxito.
3. Tras la verificación legítima, los endpoints de personal funcionan según el diseño.
4. Los sumideros alternativos (`set_my_role`, metadatos de signup) no pueden recrear el bypass.
5. Las pruebas de regresión anteriores están en CI.